

REPORTE DE ANÁLISIS Y PLANIFICACIÓN DEL PENTEST

AuroraMarket

Preparado para	Aurora Market
Preparado por	Berenice Lozano Hernández
Fecha	Septiembre 2026
Clasificación	CONFIDENCIAL
Estado	Planificación previa a pruebas técnicas

Este documento describe cómo se abordaría la evaluación. No se han ejecutado pruebas técnicas ni se presentan vulnerabilidades como hallazgos confirmados.

Tabla de contenidos

1. Executive Summary
2. Scope and Methodology
3. Attack Path Summary
4. Findings Summary
5. Detailed Findings / Áreas de evaluación
6. Risk Ratings
7. Remediation Recommendations
8. Appendix

Marco de referencia: ISSAF, complementado con prácticas de evaluación de aplicaciones web y reconocimiento controlado.

1. Executive Summary

El **objetivo concreto del pentest de Aurora Market** es evaluar, de forma controlada y autorizada, qué tan expuesta se encuentra su aplicación web ante posibles ataques y qué impacto podrían tener las debilidades encontradas sobre la organización. La evaluación busca transformar una sospecha de exposición de información entre cuentas en evidencia técnica y útil para la toma de decisiones, sin poner en riesgo la operación ni la información real de los clientes.

La necesidad de esta evaluación se origina en un reporte de un usuario que afirmó haber visualizado información que aparentemente pertenecía a otra cuenta. Aunque Aurora Market no pudo confirmar que se tratara de un ataque, el evento es una señal suficiente para realizar una revisión formal de seguridad. El pentest permitirá determinar si existen vulnerabilidades relacionadas con autenticación, sesiones, control de acceso, manejo de entradas o exposición de información y valorar su posible impacto.

El resultado esperado no es solamente una lista de problemas. Aurora Market necesita conocer qué riesgos son reales, qué tan relevantes son para el negocio y qué medidas pueden reducirlos. Por ello, cada hallazgo deberá documentarse con evidencia, impacto y una recomendación de remediación.

Postura de seguridad actual: no determinada hasta ejecutar la evaluación.

Hallazgos confirmados: 0 en esta fase de planificación. Las pruebas técnicas aún no se han ejecutado.

2. Scope and Methodology

2.1 Alcance autorizado

El alcance comprende exclusivamente la aplicación web de Aurora Market autorizada para la evaluación. Se analizarán las funcionalidades accesibles, mecanismos de autenticación, gestión de sesiones, tipos de usuarios y componentes de la aplicación que formen parte del alcance acordado.

Fuera de alcance

- Redes sociales de Aurora Market.
- Equipos personales de empleados.
- Cuentas de correo electrónico.
- Proveedores externos y otros sistemas que no formen parte del alcance.
- Cualquier acción que pueda interrumpir la plataforma o afectar información real de clientes.

2.2 Autorización y condiciones

Antes de iniciar las pruebas debe contar con autorización formal de Aurora Market, con límites claros sobre los sistemas, acciones y horarios permitidos. Las pruebas se realizarán durante horarios de menor actividad y se priorizarán técnicas de bajo impacto.

2.3 Enfoque y metodología

Tipodepentest: Gray-box. El equipo recibe información parcial sobre la aplicación, como su existencia, base de datos, mecanismos de autenticación y tipos de usuarios, pero no dispone de todos los detalles internos. Esto permite simular un escenario en el que un atacante posee cierta información previa y debe descubrir el resto de la superficie de ataque.

Metodología principal: ISSAF (Information Systems Security Assessment Framework). Se utilizará como marco para organizar los activos, consideraciones éticas y legales, tipos de pruebas, procesos y actividades, herramientas y técnicas y reporte de resultados.

2.4 Horario propuesto

Se propone una ventana de **23:00 a 02:00 horas**, sujeta a la confirmación de Aurora Market. La elección busca coincidir con un periodo de menor actividad, reducir el número de usuarios conectados y disminuir el posible impacto operativo. La ventana definitiva deberá ser aprobada por la empresa.

2.5 Recopilación de información: fuentes y métodos

Se combinarán **fuentes internas** y **fuentes abiertas (OSINT)**. De Aurora Market se analizará la información ya proporcionada sobre la aplicación, autenticación, base de datos y tipos de usuarios. Mediante OSINT se buscará información pública relacionada con el dominio y la aplicación, como dominios o subdominios publicados, tecnologías identificables públicamente y otros elementos que ayuden a conocer la superficie de exposición. La finalidad es orientar las pruebas posteriores sin ampliar el alcance.

2.6 Herramientas y propósito

Recurso	Uso dentro del escenario	Propósito
Nmap	Reconocimiento de sistemas autorizados	Identificar puertos y servicios expuestos para conocer la superficie de ataque.
OWASP ZAP	Evaluación de la aplicación web	Analizar solicitudes/respuestas y buscar posibles problemas de seguridad.
OSINT	Recopilación previa	Obtener información pública sobre el objetivo, sin atacar sistemas externos.
Navegador / revisión manual	Análisis funcional	Observar flujos, autenticación, sesiones, roles y comportamiento de la aplicación.



3. Attack Path Summary

Como todavía no se han ejecutado pruebas, el siguiente es un **camino de ataque planificado**, no un ataque realizado. Su función es mostrar cómo se conectarán las fases de la evaluación.

Paso 1	Reconocimiento	Recopilar información interna y OSINT y delimitar la superficie de ataque autorizada.
Paso 2	Identificación	Analizar puertos, servicios, funcionalidades, autenticación, sesiones y roles.
Paso 3	Análisis de vulnerabilidades	Usar Nmap y OWASP ZAP, junto con revisión manual, para localizar posibles debilidades.
Paso 4	Validación / explotación	Comprobar únicamente las vulnerabilidades pertinentes, evitando interrupciones y datos reales
Paso 5	Impacto e informe	Determinar el alcance del riesgo, documentar evidencia y proponer remediaciones.

Fases aplicadas al caso: Reconocimiento → Análisis de vulnerabilidades → Explotación → Post-explotación → Informe.

4. Findings Summary

No se presentan vulnerabilidades confirmadas porque la actividad solicita planificar el pentest y expresamente indica que no es necesario ejecutar las pruebas. Por tanto, esta tabla funciona como estructura de registro para los hallazgos que se obtengan durante una futura ejecución autorizada.

ID	Área / posible hallazgo	Sistema	Severidad	CVSS
P-001	Control de acceso / exposición entre cuentas	Aplicación web	Por determinar	Por determinar
P-002	Autenticación y gestión de sesiones	Aplicación web	Por determinar	Por determinar
P-003	Validación de entradas / exposición de información	Aplicación web	Por determinar	Por determinar

Estos son **ámbitos de evaluación previstos**, no afirmaciones de que las vulnerabilidades existan. La confirmación dependerá de las pruebas autorizadas.

5. Detailed Findings / Áreas de evaluación

P-001 — Control de acceso y posible exposición entre cuentas

Qué se evaluaría: si un usuario puede acceder a información o funciones que corresponden a otra cuenta o rol. **Cómo:** revisar flujos de usuario, sesiones, identificadores y controles de autorización de forma controlada. **Con qué:** OWASP ZAP y revisión manual. **Por qué:** el escenario parte de un reporte de posible exposición de información entre cuentas.

P-002 — Autenticación y gestión de sesiones

Qué se evaluaría: mecanismos de inicio de sesión, manejo de sesiones y separación entre tipos de usuarios. **Cómo:** observar solicitudes y respuestas y comprobar de manera controlada si los controles funcionan como se espera. **Con qué:** OWASP ZAP y navegador. **Por qué:** la autenticación es un componente conocido del escenario y puede influir directamente en la protección de cuentas.

P-003 — Validación de entradas y exposición de información

Qué se evaluaría: si entradas proporcionadas por usuarios o funcionalidades de la aplicación pueden producir comportamientos inseguros o revelar información que no debería estar disponible. **Cómo:** identificar puntos de entrada y revisar las respuestas de la aplicación dentro del alcance. **Con qué:** OWASP ZAP y revisión manual. **Por qué:** permite determinar si existe una vía técnica que explique una exposición de información.

P-004 — Servicios y superficie expuesta

Qué se evaluaría: puertos y servicios disponibles en los sistemas expresamente autorizados. **Cómo:** realizar descubrimiento y enumeración controlados. **Con qué:** Nmap. **Por qué:** conocer qué servicios están expuestos ayuda a decidir qué componentes requieren análisis posterior y evita pruebas a ciegas.

6. Risk Ratings

La severidad definitiva se asignará únicamente después de validar cada hallazgo y valorar su impacto, probabilidad y alcance. No se asigna un CVSS definitivo en esta etapa porque todavía no existe evidencia técnica.

Nivel	Referencia	Ejemplo aplicado al escenario
Crítico	9.0–10.0	Compromiso grave de cuentas o acceso amplio a información sensible.
Alto	7.0–8.9	Vulnerabilidad con impacto significativo, como una escalada de privilegios relevante.
Medio	4.0–6.9	Debilidad que requiere condiciones adicionales y cuyo impacto es limitado.
Bajo	0.1–3.9	Divulgación de información menor o recomendación de hardening.

Regla de reporte: un resultado de herramienta no se convierte automáticamente en vulnerabilidad. Debe existir análisis, evidencia y validación suficiente.

7. Remediation Recommendations

Las siguientes medidas son recomendaciones preventivas alineadas con las áreas que se pretende evaluar. La prioridad definitiva deberá ajustarse a los hallazgos reales obtenidos durante la ejecución.

1. Fortalecer el control de acceso

Verificar que cada usuario solo pueda consultar y modificar los recursos que le corresponden y que las comprobaciones de autorización se realicen del lado del servidor.

2. Revisar autenticación y sesiones

Revisar la gestión de sesiones, expiración, invalidación al cerrar sesión y separación de privilegios entre los diferentes tipos de usuarios.

3. Validar entradas y respuestas

Implementar validación adecuada de entradas y evitar que las respuestas de la aplicación revelen información innecesaria o datos pertenecientes a otros usuarios.

4. Reducir la superficie expuesta

Revisar los servicios identificados durante el reconocimiento y mantener expuestos únicamente los necesarios para la operación de la aplicación.

5. Registrar y revisar eventos de seguridad

Mantener registros útiles de autenticación, errores y eventos relevantes para facilitar la detección y posterior investigación de comportamientos anómalos.

6. Repetir la evaluación después de corregir

Una vez aplicadas las correcciones, realizar una validación posterior para comprobar que los riesgos identificados fueron mitigados.

8. Appendix

A. Checklist de ejecución propuesta

- Confirmar autorización formal y alcance.
- Confirmar ventana de pruebas de menor actividad.
- Documentar activos y datos iniciales proporcionados por Aurora Market.
- Realizar recopilación OSINT dentro de los límites acordados.
- Realizar reconocimiento con Nmap sobre objetivos autorizados.
- Analizar la aplicación web con OWASP ZAP y revisión manual.
- Registrar evidencia de cada posible hallazgo.
- Validar vulnerabilidades sin afectar disponibilidad ni datos reales.
- Evaluar impacto y asignar severidad/CVSS cuando exista evidencia suficiente.
- Preparar informe y recomendaciones.

B. Información que deberá registrarse durante la ejecución

- Fecha y hora de cada prueba.
- Sistema, dominio, endpoint o servicio afectado.
- Herramienta y técnica utilizada.
- Resultado observado y evidencia.
- Impacto potencial.
- Acción de remediación recomendada.

C. Nota sobre el estado de este documento

Este reporte corresponde a la fase de análisis y planificación de la Actividad 01. No documenta accesos obtenidos, credenciales, hashes ni vulnerabilidades explotadas, porque las pruebas técnicas no forman parte de lo solicitado en esta actividad.

— Fin del Reporte —